

TP 4.2 – Détection d’attaques avec Suricata IDS/IPS sur pfSense

1. Introduction

Dans les précédents travaux pratiques, la mise en place de pfSense a permis d’assurer une première couche de sécurité grâce au filtrage des flux réseau. Cependant, cette approche reste limitée car elle ne permet pas d’analyser le contenu des paquets ni de détecter des comportements malveillants circulant dans un trafic autorisé comme HTTP ou HTTPS.

Pour renforcer la sécurité du réseau, les systèmes IDS/IPS (Intrusion Detection System / Intrusion Prevention System) sont utilisés dans les environnements professionnels. Suricata est un moteur IDS/IPS moderne capable d’analyser le trafic réseau en temps réel, d’identifier des signatures d’attaques connues et de réagir automatiquement en cas d’activité suspecte.

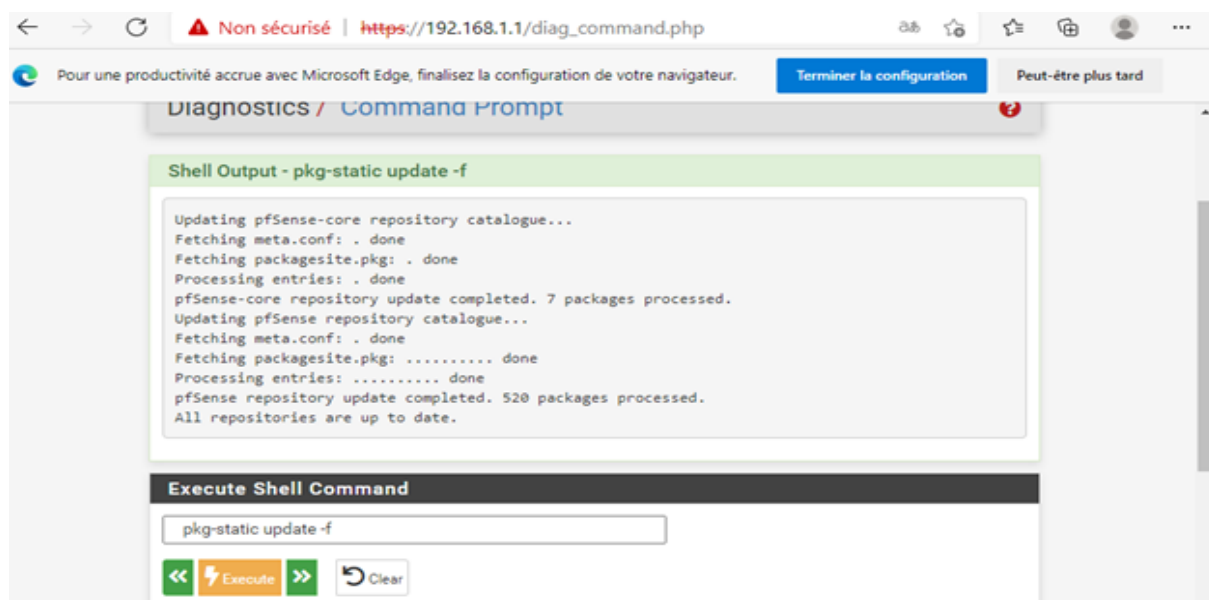
L’objectif de ce TP est donc de mettre en place Suricata sur pfSense afin de détecter, analyser et éventuellement bloquer des attaques provenant d’une machine attaquante.

2. Installation de Suricata

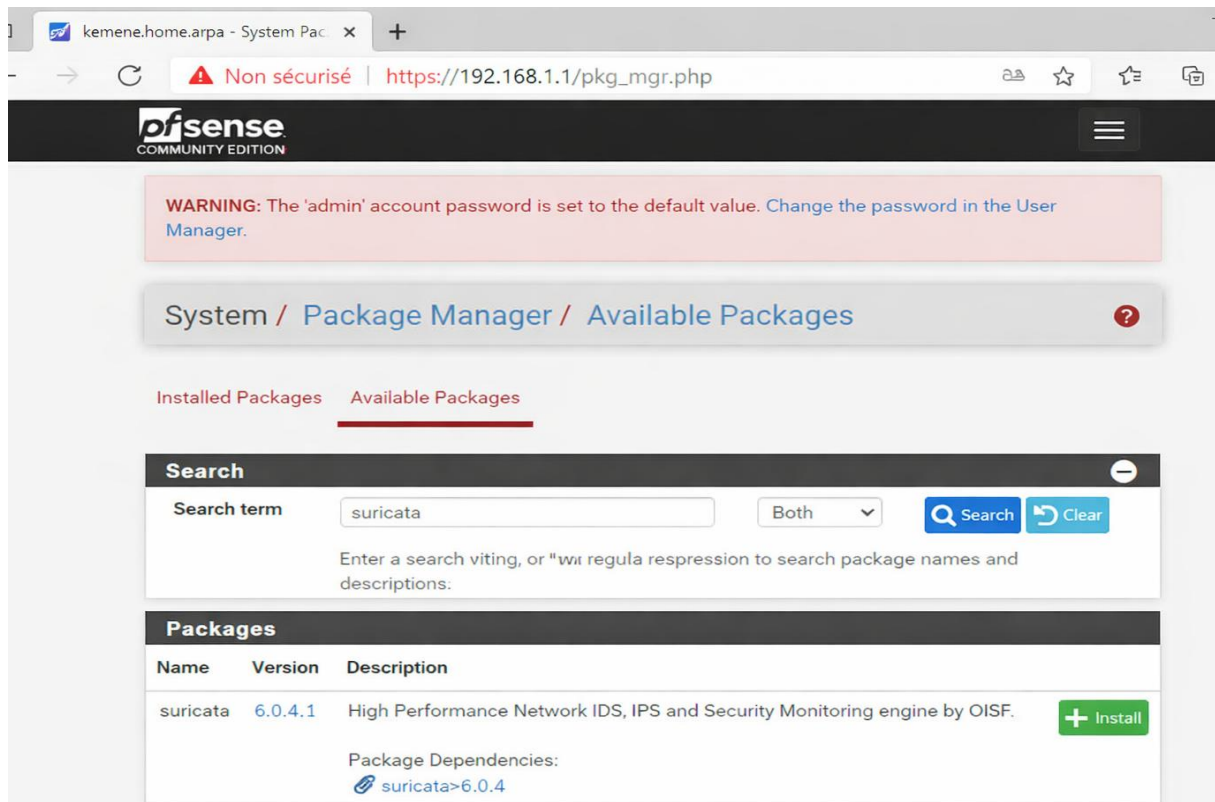
Suricata est installé via le gestionnaire de paquets de pfSense. Une fois l’installation terminée, le service devient disponible dans le menu des services de sécurité réseau.

Capture d’écran : Installation de Suricata dans Package Manager

- Commande pour forcer la mise à jour du gestionnaire de paquets : `pkg-static update -f`

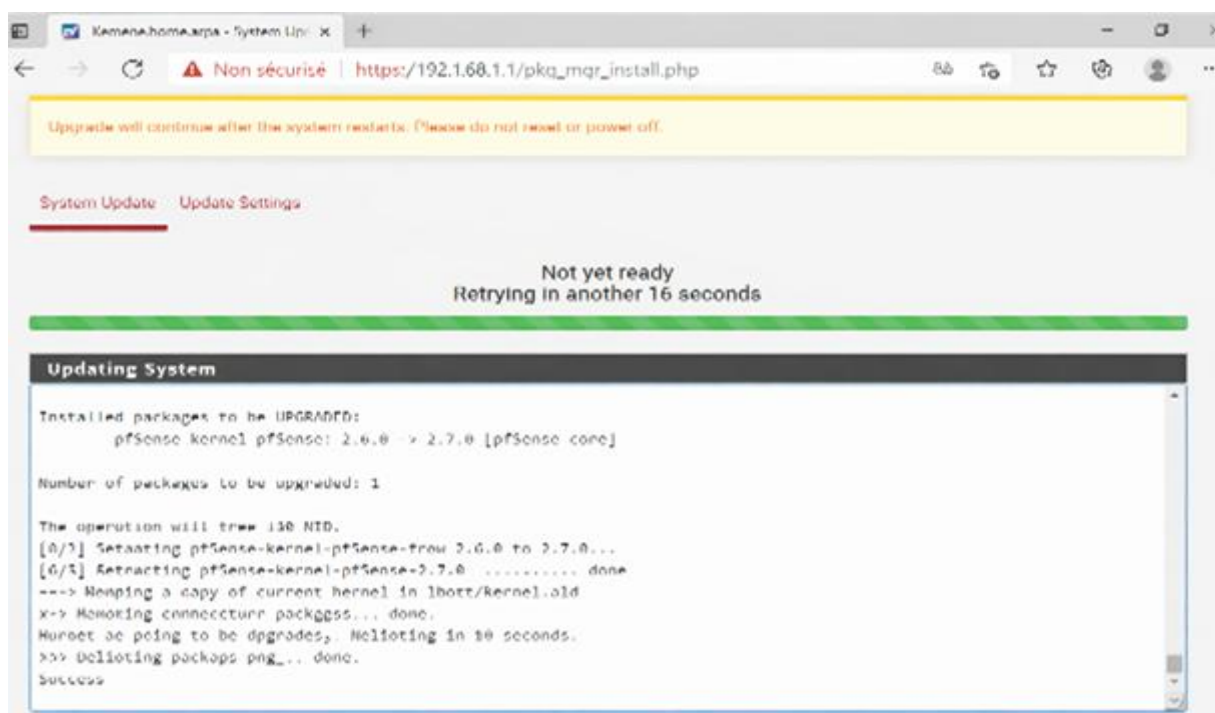


➤ Téléchargement de suricata via l'interface pfsense



Cette étape permet d'ajouter un moteur d'analyse réseau performant directement intégré à pfSense, capable de traiter des milliers de connexions par seconde.

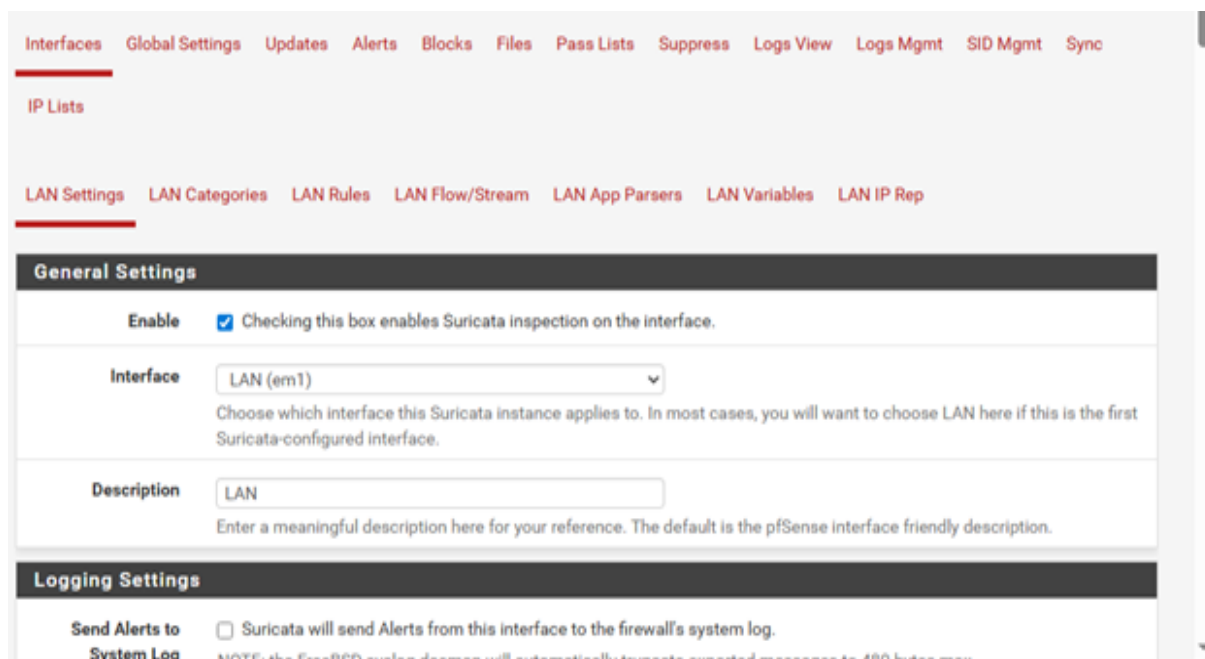
➤ Mise à jour



3. Activation sur l'interface LAN

Après installation, Suricata est activé sur l'interface LAN du pare-feu. Ce choix est stratégique car le réseau interne est souvent la cible principale des attaques après compromission d'une machine.

Capture d'écran : Configuration de Suricata sur l'interface LAN



The screenshot shows the Suricata configuration page in pfSense. The top navigation bar includes links like Interfaces, Global Settings, Updates, Alerts, Blocks, Files, Pass Lists, Suppress, Logs View, Logs Mgmt, SID Mgmt, and Sync. The 'IP Lists' section is active, showing 'LAN Settings', 'LAN Categories', 'LAN Rules', 'LAN Flow/Stream', 'LAN App Parsers', 'LAN Variables', and 'LAN IP Rep'. The 'General Settings' section has 'Enable' checked with a note: 'Checking this box enables Suricata inspection on the interface.' The 'Interface' dropdown is set to 'LAN (em1)' with a note: 'Choose which interface this Suricata instance applies to. In most cases, you will want to choose LAN here if this is the first Suricata-configured interface.' The 'Description' field is set to 'LAN' with a note: 'Enter a meaningful description here for your reference. The default is the pfSense interface friendly description.' The 'Logging Settings' section has 'Send Alerts to System Log' checked with a note: 'Suricata will send Alerts from this interface to the firewall's system log.' A note at the bottom states: 'NOTE: the EtnaBCE Suricata daemon will automatically truncate oversized messages to 4096 bytes max.'

L'activation sur cette interface permet d'analyser tout le trafic entrant et sortant du réseau local.

4. Activation des règles de détection

Pour assurer une détection efficace, les règles (IDS) de sécurité ont été activées, notamment celles issues de la base **Emerging Threats (ET Open)**. Ces règles contiennent des signatures correspondant à des attaques connues. Permettant de détecter des scans réseau, des tentatives d'exploitation, des connexions suspectes ou encore des comportements anormaux.



The screenshot shows the Suricata rule selection page. The top navigation bar includes links like Sync and IP Lists. The main heading is 'Please Choose The Type Of Rules You Wish To Download'. There are two options: 'Install ETOpen Emerging Threats rules' (checked) and 'Use a custom URL for ETOpen downloads' (unchecked). A note at the bottom states: 'Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETOpen rules.'

5. Détection d'un scan réseau

Une première attaque est simulée depuis la machine Kali Linux à l'aide d'un scan Nmap. Ce type d'attaque est souvent utilisé pour cartographier un réseau avant une intrusion.

Commande utilisée :

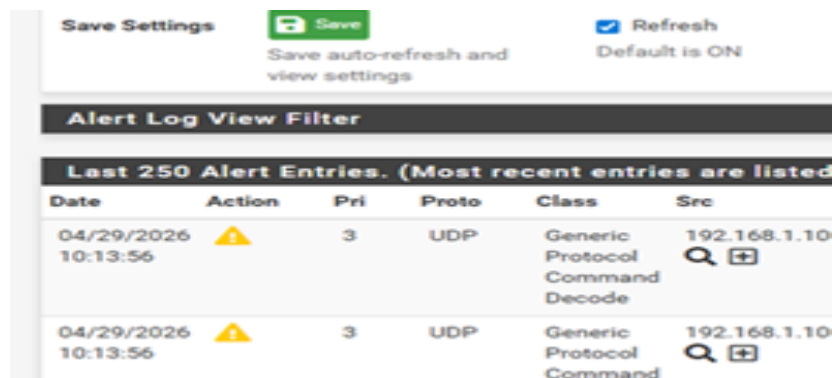
```
nmap -sS 192.168.1.10
```

```
└─$ nmap -sS 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 10:09 +0200
Nmap scan report for 192.168.1.10
Host is up (0.0025s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:B9:97:BF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.42 seconds
```

Capture d'écran : Suricata actif et détection du scan Nmap

On retourne dans l'interface web de pfsense on entre dans service puis dans suricata et on clique alerte :



The screenshot shows the 'Alert Log View Filter' section of the Suricata interface. It displays a table of the last 250 alert entries. Two alerts are visible, both from 192.168.1.10 on 04/29/2026 at 10:13:56. The alerts are categorized as 'Generic Protocol Command' with a priority of 3 and a protocol of UDP. The action is marked with a yellow warning icon.

Date	Action	Pri	Proto	Class	Src
04/29/2026 10:13:56		3	UDP	Generic Protocol Command	192.168.1.10
04/29/2026 10:13:56		3	UDP	Generic Protocol Command	192.168.1.10

Suricata détecte immédiatement le comportement anormal et génère des alertes correspondant à une activité de type reconnaissance réseau.

6. Détection d'une attaque avancée

Une seconde simulation est effectuée à l'aide d'un outil d'exploitation comme Metasploit, visant un service vulnérable.

- **use auxiliary/scanner/smb/smb_version**
- **RHOSTS 192.168.1.10-**
- **run**

Alert and Block Settings	
Block Offenders	☒ Checking this option will automatically block hosts that generate a Suricata alert.
IPS Mode	Legacy Mode Select blocking mode operation. Legacy Mode inspects copies of packets while Inline Mode inserts the Suricata inspection engine into the network stack between the NIC and the OS. Default is Legacy Mode. Legacy Mode uses the PCAP engine to generate copies of packets for inspection as they traverse the interface. Some "leakage" of packets will occur before Suricata can determine if the traffic matches a rule and should be blocked. Inline mode instead intercepts and inspects packets before they are handed off to the host network stack for further processing. Packets matching DROP rules are simply discarded (dropped) and not passed to the host network stack. No leakage of packets occurs with Inline Mode. WARNING: Inline Mode only works with NIC drivers which properly support Netmap! Supported drivers include: bnxt, cc, cxgbe, cxl, em, ena, ice, igb, igc, ix, ixgbe, ixl, lem, re, vmx, vtnet. If problems are experienced with Inline Mode, switch to Legacy Mode instead.
Kill States	☒ Checking this option will kill firewall states for the blocked IP. Default is Checked.
Which IP to Block	BOTH Select which IP extracted from the packet you wish to block. Choosing BOTH is suggested, and it is the default value.
Block On DROP Only	☐ Checking this option will insert blocks only when rule signatures having the DROP action are triggered. When not checked, any rule action (ALERT or DROP) will generate a block of the offending host. Default is Not Checked.
IP Pass List	default Choose the Pass List you want this interface to use. Addresses in a Pass List are never blocked. Select "none" to prevent use of a Pass List. The default Pass List adds Gateways, DNS servers, locally-attached networks, the WAN IP, VPNs and VIPs. Create a Pass List with an alias to customize whitelisted IP addresses. This option will only be used when block offenders is on. Choosing "none" will disable Pass List generation. View List
Enable Passlist Debugging Log	☐ Checking this option will enable detailed Passlist operations logging to file /var/log/suricata/suricata_em144392/passlist_debug.log. Default is Not Checked.

On distingue alors deux modes de fonctionnement :

- **IDS** : détection uniquement
- **IPS** : détection + blocage automatique

8. Analyse des règles et options avancées

Suricata propose une gestion avancée des règles de sécurité permettant de filtrer les alertes selon leur gravité, leur type ou encore leur protocole. Il est également possible d'ajouter des règles personnalisées adaptées à un environnement spécifique.

9. Conclusion

Ce TP a permis de mettre en évidence l'importance d'un système IDS/IPS dans une architecture réseau sécurisée. Contrairement à un pare-feu classique qui filtre uniquement les flux, Suricata analyse le contenu du trafic et détecte les comportements suspects.

L'association pfSense + Suricata permet ainsi de construire une défense en profondeur :

- pfSense contrôle les accès réseau
- Suricata analyse et détecte les attaques
- Le mode IPS permet une réaction automatique

Ce TP permet de comprendre les bases des systèmes de détection utilisés dans les SOC modernes et renforce les compétences en cybersécurité opérationnelle.